



Final Technical Report NEMU IPB

Perancangan dan Implementasi Protokol Keamanan Informasi pada Sistem NEMU IPB

Kelompok 7

Salma Putri Hanifah	G6401231010
Marsya Hasna Khairunnisa	G6401231015
Lathiifa Zahira Yahya	G6401231154

1. Ringkasan Sistem

NEMU IPB adalah aplikasi web lost and found untuk civitas akademika IPB. Sistem ini membantu pengguna mencatat dan menelusuri barang hilang maupun barang temuan secara terstruktur. Fitur utama yang didukung meliputi pelaporan kehilangan, pelaporan barang temuan, klaim barang menggunakan laporan kehilangan, dropoff barang untuk laporan penemuan, verifikasi laporan oleh admin, verifikasi klaim/dropoff, monitoring status, notifikasi, activity log, dashboard/analisis, dan serah terima barang.

Karena sistem menyimpan data user, laporan, klaim, barang, notifikasi, activity log, dan dokumen serah terima, rancangan NEMU IPB perlu memperhatikan aspek Keamanan Informasi. Fokus keamanan sistem meliputi authentication, authorization, accounting, password hashing, session/token validation, role-based access control, input validation, secure communication, CORS, secret management, document hashing, digital signature, dan audit trail.

2. Tujuan Sistem

Tujuan sistem NEMU IPB adalah:

1. Menyediakan aplikasi lost and found berbasis web untuk civitas akademika IPB.
2. Memudahkan pelaporan barang hilang dan barang temuan.
3. Memudahkan pencarian, pengecekan detail, dan pemantauan status barang.
4. Membantu admin melakukan verifikasi laporan, klaim, dan drop off secara terstruktur.
5. Melindungi data dan proses sistem melalui autentikasi, otorisasi, dan validasi input.
6. Meningkatkan akuntabilitas aktivitas admin melalui activity log.
7. Menjaga integritas dokumen serah terima melalui document hashing dan digital signature.

3. Arsitektur Sistem

NEMU IPB menggunakan arsitektur client-server. Aktor sistem terdiri dari Civitas Akademika IPB dan Admin. Frontend React berperan sebagai presentation layer yang digunakan pengguna untuk berinteraksi dengan sistem. Backend FastAPI berperan sebagai API server yang menerima request, melakukan validasi, menjalankan business logic, dan mengakses database.

Pada backend, router berfungsi sebagai endpoint handler. Service layer mengelola logika bisnis seperti proses laporan, klaim, dropoff, notifikasi, activity log, dan serah terima. SQLAlchemy digunakan sebagai ORM untuk berkomunikasi dengan PostgreSQL. Alembic digunakan untuk mengelola database migration.

Komponen pendukung backend meliputi notification service, activity log service, dan digital signature/serah terima service. Pada production, komunikasi frontend-backend harus menggunakan HTTPS. Frontend HTTPS tidak boleh memanggil backend HTTP karena dapat menyebabkan mixed content dan kegagalan request browser. Konfigurasi frontend menggunakan REACT_APP_API_BASE_URL dan menghapus trailing slash pada base URL agar request mengarah langsung ke endpoint final.

4. Teknologi yang Digunakan

Komponen	Teknologi	Fungsi
Frontend	React	Antarmuka pengguna untuk civitas dan admin.
Backend	FastAPI	API server, routing, validasi request, dan response JSON.
Database	PostgreSQL	Penyimpanan data user, barang, laporan, klaim, notifikasi, serah terima, dan log.
ORM	SQLAlchemy	Menghubungkan model Python dengan tabel database.
Migration	Alembic	Mengelola perubahan schema database.
Authentication	JWT bearer token/session	Mengelola akses setelah login dan endpoint protected.
Password hashing	Bcrypt melalui Passlib	Menyimpan password sebagai hash, bukan plaintext.

CORS	FastAPI CORSMiddleware	Membatasi origin browser yang boleh mengakses API sebagai kontrol tambahan.
Secure communication	HTTPS pada production	Melindungi token, data user, laporan, klaim, barang, dan status selama transmisi.
Secret management	Environment variable	Menyimpan DATABASE_URL, SECRET_KEY, FERNET_KEY, ALGORITHM, dan konfigurasi penting lain di luar kode.
Digital signature	RSA dan SHA-256	Menandatangani dan memverifikasi dokumen serah terima.
Activity log	Service dan tabel activity_logs	Mencatat aktivitas penting untuk audit trail.
Notifikasi	Router/service notifikasi	Memberi informasi perubahan status kepada user.

5. Struktur Repository

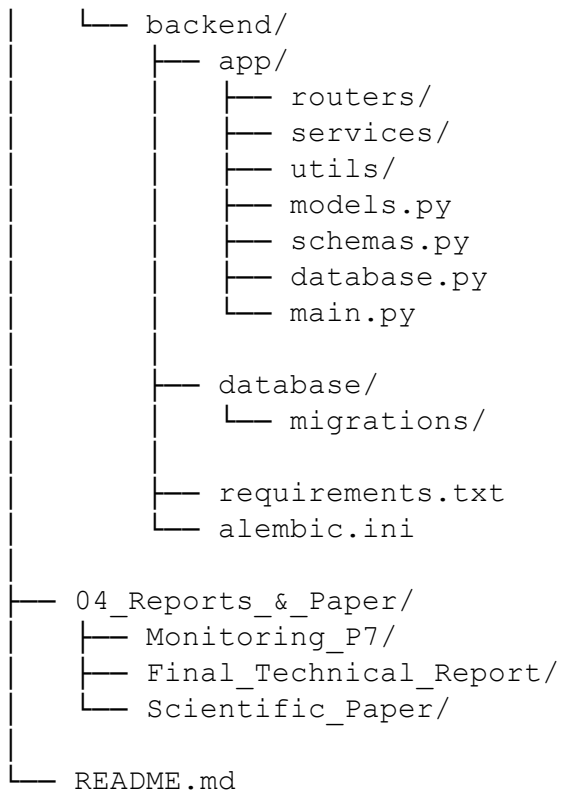
Struktur repository yang relevan:

KOM1315_SmtGenap26_Kelompok07_NEMUIPB/

```

|
|— 01_Proposal_&_Analisis/
|   |— Proposal_Teknis.pdf
|   |— Threat_Modeling.pdf
|
|— 02_Design_Documents/
|   |— ERD_Modified.png
|   |— Architecture_Diagram.pdf
|   |— Testing_Plan.pdf
|
|— 03_Source_Code/
|   |— frontend/
|       |— public/
|       |— src/
|       |— package.json
|       |— package-lock.json

```



6. Fitur Utama Sistem

Fitur utama NEMU IPB meliputi:

- Login/logout.
- Membuat laporan kehilangan.
- Melaporkan barang temuan.
- Mengecek status laporan.
- Mencari barang.
- Melihat detail barang.
- Mengecek update status barang.
- Klaim barang menggunakan laporan kehilangan.
- Dropoff barang untuk laporan penemuan.
- Meninjau detail laporan oleh admin.
- Menyetujui/menolak laporan oleh admin.
- Verifikasi klaim barang.
- Verifikasi dropoff barang.
- Memperbarui status barang.
- Mengirim notifikasi.
- Mencatat activity log.
- Membuat dokumen serah terima.
- Dashboard/analisis admin.
- Memantau aktivitas admin.

7. Desain Keamanan Informasi

Desain keamanan informasi pada NEMU IPB mencakup:

- **Authentication:** user melakukan login menggunakan email/username dan password.
- **Password hashing:** password tidak disimpan dalam bentuk plaintext, tetapi dalam bentuk password_hash menggunakan bcrypt.
- **Session/token validation:** endpoint protected membutuhkan token/session valid sebelum request diproses.
- **Authorization:** role civitas dan admin menentukan hak akses. Endpoint admin harus menolak akses dari role civitas.
- **Accounting:** aktivitas penting dicatat melalui activity log untuk mendukung audit trail.
- **Input validation:** validasi dilakukan untuk mencegah data kosong, format salah, tanggal tidak valid, dan input berbahaya.
- **API security:** endpoint protected memerlukan token, dan endpoint admin memerlukan role admin.
- **CORS:** backend menggunakan CORS middleware. Kode memiliki daftar origin valid seperti `https://nemui.pb.vercel.app`, `http://localhost:3000`, dan `http://127.0.0.1:3000`, tetapi konfigurasi middleware saat ini masih memakai wildcard `allow_origins=["*"]`. Untuk production, origin valid perlu didaftarkan eksplisit tanpa trailing slash. CORS bukan pengganti authentication atau authorization.
- **Document hashing:** dokumen serah terima memiliki hash untuk mendeteksi perubahan isi dokumen.
- **Digital signature:** signature mendukung integritas dan non-repudiation pada dokumen serah terima.
- **Public key verification:** public key digunakan untuk memverifikasi digital signature.
- **Secure communication:** HTTPS wajib digunakan pada production. Semua request production ke backend harus memakai `https://` untuk mencegah token dan data sensitif lewat jalur tidak aman.
- **Mixed content prevention:** frontend HTTPS harus memanggil backend HTTPS final, bukan HTTP yang bergantung pada redirect.
- **Secret/private key management:** secret dan private key harus disimpan aman menggunakan environment variable atau secret manager, bukan di repository. Backend menggunakan `DATABASE_URL`, `SECRET_KEY`, `FERNET_KEY`, `ALGORITHM`, dan `ACCESS_TOKEN_EXPIRE_MINUTES`; frontend menggunakan `REACT_APP_API_BASE_URL`.

8. Manajemen Data dan Database

ingin menerapkan invalidasi token di server.

9.2 Laporan Kehilangan

Civitas mengisi data laporan kehilangan melalui frontend. Backend menerima request pada endpoint laporan, memvalidasi token user, memvalidasi input menggunakan schema, lalu menyimpan data barang dan laporan ke PostgreSQL melalui SQLAlchemy. Aspek keamanan yang terlibat adalah token validation, input validation, dan perlindungan data laporan.

Validasi input dilakukan melalui Pydantic schema, misalnya field laporan tidak boleh kosong, tanggal kejadian tidak boleh melebihi hari ini, dan dokumentasi harus berformat gambar yang didukung. Validasi ini membantu menjaga kualitas data dan mengurangi risiko penyalahgunaan input.

9.3 Laporan Penemuan dan Dropoff Barang

Civitas melaporkan barang temuan melalui frontend. Backend menyimpan data barang temuan dan laporan penemuan. Setelah admin menyetujui laporan penemuan, sistem dapat menghasilkan kode dropoff yang disampaikan melalui notifikasi. Saat barang diserahkan, admin memverifikasi kode dropoff. Aspek keamanan yang terlibat adalah authorization admin, validasi status laporan, notifikasi, dan activity log.

9.4 Klaim Barang

Civitas mengajukan klaim terhadap barang temuan menggunakan laporan kehilangan miliknya. Backend memvalidasi token, memeriksa kepemilikan laporan kehilangan, memeriksa status barang, dan menolak klaim yang tidak sesuai aturan sistem. Jika valid, klaim disimpan di database dengan status proses. Aspek keamanan yang terlibat adalah authorization berbasis kepemilikan data, input validation, dan integritas klaim.

9.5 Verifikasi Admin

Admin meninjau laporan, klaim, atau dropoff melalui frontend admin. Backend memvalidasi token dan role admin sebelum menjalankan proses verifikasi. Hasil verifikasi memperbarui status laporan, klaim, atau barang. Sistem juga membuat notifikasi dan activity log. Aspek keamanan yang terlibat adalah role-based access control, audit trail, dan pencegahan manipulasi status oleh user tidak berwenang.

9.6 Serah Terima Barang

Setelah klaim diterima dan proses pengembalian barang berjalan sesuai alur, sistem membuat dokumen serah terima. Dokumen tersebut diberi dokumen_hash dan digital_signature, serta menyimpan public_key untuk verifikasi. Beberapa field sensitif pada dokumen serah terima dienkripsi sebelum disimpan. Aspek keamanan yang terlibat adalah document hashing, digital signature, public key verification, integritas dokumen, dan non-repudiation.

9.7 Notifikasi dan Activity Log

Setiap perubahan status penting, seperti laporan disetujui/ditolak, klaim diterima/ditolak, atau dropoff diverifikasi, dapat menghasilkan notifikasi kepada user terkait. Aktivitas penting, terutama aksi admin, dicatat pada activity log. Aspek keamanan yang terlibat adalah accounting, accountability, dan audit trail.

10. Pengujian Sistem

Rencana pengujian keamanan mencakup:

- Authentication: login valid, password salah, user tidak ditemukan.
- Authorization: civitas tidak dapat mengakses endpoint admin.
- Accounting / Activity Log: aksi admin tercatat pada activity log.
- Session/token validation: endpoint protected menolak request tanpa token atau token invalid.
- Password hashing: password tidak tersimpan plaintext di database.
- API security: endpoint admin hanya bisa diakses role admin.
- CORS dan secure communication: origin production harus dibatasi dan request production harus memakai HTTPS.
- Input validation: field kosong, format salah, dan input berbahaya ditolak.
- Report verification: approve/reject laporan memperbarui status, notifikasi, dan log.
- Claim/dropoff verification: klaim/dropoff hanya diverifikasi admin dan memperbarui data terkait.
- Digital signature dan document integrity: dokumen asli valid dan dokumen termodifikasi gagal diverifikasi.
- Database integrity: request gagal tidak menyebabkan perubahan data parsial.
- Schema consistency: migration Alembic sesuai dengan model dan tabel penting tersedia di database production.

11. Risiko dan Mitigasi

Risiko	Dampak	Mitigasi
Unauthorized access	Data protected dapat diakses pihak tidak sah.	Token validation pada endpoint protected.
Broken access control	Civitas dapat menjalankan aksi admin.	Role-based access control dan pemeriksaan role pada backend.
Password leakage	Kredensial user dapat disalahgunakan.	Password hashing, tidak menyimpan plaintext, tidak mencatat password di log.

Token/session misuse	Token dicuri dan digunakan ulang.	Expiry token, logout client-side, HTTPS saat deployment, rekomendasi session invalidation server-side.
Mixed content	Frontend HTTPS memanggil backend HTTP sehingga request diblokir browser atau komunikasi menjadi tidak aman.	Gunakan REACT_APP_API_BASE_URL berbasis https://, hindari redirect HTTP, dan pastikan endpoint production final sudah HTTPS.
CORS misconfiguration	API dapat dipanggil dari origin browser yang tidak dikenal.	Batasi allow_origins ke origin frontend valid tanpa trailing slash; CORS tetap dipadukan dengan token dan RBAC.
Manipulasi status laporan/klaim	Status tidak sesuai proses verifikasi.	Endpoint admin, validasi status, activity log.
Manipulasi dokumen serah terima	Dokumen berubah tanpa terdeteksi.	Document hashing dan digital signature.
Data tampering	Data database berubah tanpa proses sah.	Pembatasan akses database, audit log, backup.
SQL injection	Query database dimanipulasi.	ORM SQLAlchemy, validasi input, query parameterized.
XSS	Script berbahaya berjalan di frontend.	Sanitasi/escape output, validasi input, hindari render HTML mentah.
Kehilangan audit trail	Aktivitas penting tidak dapat ditelusuri.	Activity log dan backup database.
Secret/private key leakage	Token, enkripsi, atau signature dapat dipalsukan/disalahgunakan.	Environment variable, secret manager, jangan commit .env atau private key.
Data/schema tidak sinkron antar environment	Endpoint auth, session, klaim, notifikasi, atau audit log gagal karena tabel/kolom tidak sesuai.	Jalankan Alembic migration, pantau alembic_version, dan selaraskan model dengan schema database.

12. Keterbatasan dan Rekomendasi Pengembangan

Beberapa keterbatasan dan rekomendasi pengembangan:

1. HTTPS perlu diterapkan saat deployment untuk melindungi kredensial, token, dan data sensitif selama transmisi.
2. Frontend production harus memanggil backend dengan URL `https://` untuk mencegah mixed content. Endpoint sebaiknya ditulis langsung ke URL final tanpa trailing slash yang tidak diperlukan.
3. Konfigurasi CORS perlu diperketat agar `allow_origins` hanya berisi origin frontend valid, misalnya `https://nemuipb.vercel.app`, dan tidak menggunakan wildcard pada production.
4. Rate limiting untuk login perlu ditambahkan untuk mengurangi risiko brute force.
5. Backup database perlu disiapkan agar data dan audit trail tidak hilang.
6. Automated security testing dapat ditambahkan untuk menguji regression pada authentication, authorization, input validation, dan API security.
7. MFA dapat dipertimbangkan untuk akun admin apabila kebutuhan keamanan meningkat.
8. Monitoring log perlu diterapkan agar aktivitas mencurigakan dapat dideteksi.
9. Penyimpanan key perlu ditingkatkan menggunakan secret manager atau environment variable yang dikelola aman.
10. Alembic migration perlu dijalankan konsisten di setiap environment agar schema database sesuai dengan model dan service aplikasi.

13. Kesimpulan

NEMU IPB dirancang sebagai sistem lost and found berbasis web yang memperhatikan aspek Keamanan Informasi. Sistem mendukung proses pelaporan kehilangan, pelaporan penemuan, klaim, dropoff, verifikasi admin, notifikasi, activity log, dashboard, dan serah terima barang.

Dari sisi keamanan, NEMU IPB menerapkan atau merekomendasikan mekanisme Authentication, Authorization, Accounting, password hashing, session/token validation, role-based access control, input validation, CORS restriction, HTTPS production, secret management, audit trail, document hashing, dan digital signature. Dengan rancangan tersebut, sistem tidak hanya membantu proses operasional lost and found, tetapi juga melindungi data dan menjaga integritas proses pengembalian barang.